Комплексное практическое задание

Методические указания

Применение технологий искусственного интеллекта и машинного обучения для поиска угроз инорфмационной безопасности

Вступление

Современная информационная безопасность перестала быть исключительно областью построения периметров и настройки правил доступа к ресурсам и межсетевого экранирования.

Сегодня это, в первую очередь, наука о данных, где угроза является не просто единичным событием, а рассматривается как сложный непрерывный процесс, проявляющийся в отдельных цифровых следах, каждый со своими свойствами наблюдаемости. Контекст происходящего здесь сегодня важен как никогда.

Цель

Работая в команде, разработать аналитический продукт в сфере информационной безопасности и OSINT

Требования к выполнению

1. Работа над проектом должны быть организована в репозитории Github.
2. Проект должен включать в себя:
    1. Модуль загрузки данных пользователя (ETL), а также пример собранных данных
    2. Модуль обработки данных и ML
    3. Модуль визуализации данных
    4. Документацию (можно в виде pkgdown)
    5. MCP-сервер для взаимодействия с Вашим проектом для агентов ИИ
3. Модули проекта должны быть реализованы на языке программирования R. Допускается использование любых пакетов R.
4. Код на R должен быть оформлен в виде пакета R и включать:
    - пример данных (`data`)
    - средства сбора данных (`data-raw`)
    - сам программный код (`R`)
    - примеры (`vignettes`)

> ⓘ Shiny
>
> Архитектурно следует разделять модули обработки данных и средства отображения результатов и взаимодействия с пользователем.

> Веб-приложение для Вашего проекта, выполненное на Shiny может не входить в состав пакета (для простоты упаковки пакета), но при этом использовать (импортировать) функции из Вашего пакета.

5. Допускается использование дополнительных необходимых модулей (микросервисы, СУБД, LLM и т.д.) при условии включения сценариев их развертывании и настройки в Проект, а также их описания в документации Проекта.

Команда

1. Команда может состоять из 3-5 человек
2. Формирование команд завершается до этапа №1
3. В каждой команде участники выбирают капитана команды
4. По окончанию формирования команды и выбора задачи, капитан команды создает группу в Телеграм, добавляет участников группы, высылает ссылку преподавателю для обсуждения хода работы над заданием и консультаций по техническим вопросам.
5. Каждый член команды должен внести не менее 25% вклада в работу над проектом для команд из 3 человек,
   - 20% для команд из 4 человек
   - 15% для команд из 5 человек
6. Вклад каждого члена команды оценивается по коду/документации (LoC) в репозитории Проекта
7. Работа над проектом в репозитории для каждого члена команды должны начаться до этапа №2
8. Каждый член команды должен представить Проект хотя бы 1 раз в ходе демо на этапе или модуль Проекта на нескольких презентациях этапов (при помодульном разделении ответственности внутри команды).

Тайминг

1. Этап 1: Демонстрация концепции проекта и программной архитектуры – 2 занятие
2. Этап 2: Демонстрация Модуля ETL – 4 занятие
3. Этап 3: Перелиз-чекап – 6 занятие
4. Этап 4: Демонстрация проекта – 7-8 занятия

Принципы

Воспроизводимость

Каждая аналитическая задача должна быть оформлена как четкий, документированный и самодостаточный вычислительный процесс. Это достигается через использование скриптов на языке R и упаковку логики в R-пакеты. Ваш код и методика должны давать идентичный результат при повторном запуске Вами или другими исследователями.

Целенаправленность

Используйте современные подходы обработки данных (Tidyverse, Arrow, DuckDB, collapse), выбирайте уже реализованные на используемом стеке инструменты (переиспользование технологий)

Структуризация

Работа должна быть оформлена в соответствии с требованиями к структуре программного пакета R.

Дополнительный источник информации – https://r-pkgs.org/

Политика использования генеративных моделей и агентов

Развитие средств автоматизации деятельности человека - естественный процесс прогресса, однако новые средства нужно правильно использовать.

«AI slop» — это презрительный термин для низкокачественного и бессмысленного контента, массово сгенерированного искусственным интеллектом. Обычно он заполняет интернет-пространство, не предлагая человеку реальной ценности, смысла или оригинальности.

Чтобы не размывать ценность Вашего кода и продукта в целом, помните о базовых правилах использования агентов и LLM:

1. Использование PRD
2. Использование AGENTS.md
3. Контроль сгенерированного кода при помощи тестов (использование testthat в таком случае становится обязательным)
4. Заранее заданные правила по порядку именования файлов, функций, переменных. Стайлгайды по использованию сторонних пакетов
5. Концепция HITL (Human in the loop) – контроль сложности проекта и качества работы агентов остается за разработчиком.

Мониторинг инструментов наступательной кибербезопасности

Автоматический мониторинг и классификация возможностей инструментов пентеста в соответствии с матрицей MITRE

Идея

На основе открытых источников информации, поиска по Github, специализированных ресурсов (Packetstorm, RSS-каналы…) собрать информацию об актуальных инструментах для проведения пентеста и их классифкации в соответствии с матрицей MITRE по техникам, тактикам и процедурам (TTP).

Описание

Проект включает следующие этапы:

1. Поиск существующих или разработка новых средств сбора данных (скачивание, импорт и приведение данных к аккуратному виду) — возможно с использованием уже существующих программных сервисов/микросервисов.
2. Разработка средств анализа описания (документации) найденных программных инструментов (например `nmap`, `nikto`, `potator` и т.д.) и их классификация в соответсвии с техникамами MITRE (TTP идентификаторами, например `Tactics: Privilege Escalation, Defense Evasion, ID: T1548`).
3. Разработка средства визуализации собранных данных в виде веб-приложения или сайта (Shiny/Quarto).
4. Создание средства упаковки в контейнер (Dockerfile).
5. Разработка средства запуска веб-приложения (docker compose/podman).
6. Реадизация MCP-сервера для доступа к собранным данным AI-агентов

Ключевые навыки

R, работа с API/данными, Docker, Shiny/Quarto, суммаризация с использованием LLM, составление онтологий инструментов

Погружение в проблематику:

1. Data Driven Security
2. Работа с LLM из R
3. Реализация RAG в R

Глубокий анализ новых методов обеспечения информационной безопасности

Автоматический мониторинг новых наукоемких методов информационной безопасности

Идея

Используя появляющиеся в открытом доступе научные работы по теме информационной безопасности (защитной или наступательной) на таких сайтах как arxiv.org или CORE сформировать базу знаний о новых методах обеспечения ИБ, их месте в общем ландшафте методов и средств обеспечения кибербезопасности, проработанности темы (уровне готовности предлагаемой технологии).

Описание

Проект может включать следующие этапы:

1. Поиск существующих или разработка новых средств сбора данных (скачивание исходных текстов научных работ, импорт метаданных и приведение этих данных к аккуратному виду) — возможно с использованием уже существующих программных сервисов/микросервисов.
2. Распознавание и перевод в текстовый вид научных статей (Docling, Tika …), а также организация их хранения.
3. Анализ текстов с помощью больших языковых моделей (LLM) и разработанных промптов и правил анализа.
4. Разработка средства визуализации собранных данных в виде веб-приложения или сайта (Shiny/Quarto).
5. Создание средства упаковки в контейнер (Dockerfile).
6. Разработка средства запуска веб-приложения (docker compose/podman).
7. Реализация MCP-сервера для доступа к собранным данным AI-агентов

Ключевые навыки

R, работа с API/данными, Docker, Shiny/Quarto, суммаризация с использованием LLM, составление онтологий предметной области информационной безопасности

Погружение в проблематику:

1. Data Driven Security
2. Работа с LLM из R
3. Реализация RAG в R

Построение системы обнаружения вторжений

Обнаружение аномалий в сетевом трафике:

Фаза ETL данных

- сбор данных о сетевом трафике (zeek, NetFlow)
- очистка и нормализация данных, удаление несущественных данных
- обогащение контекстной информацией, такой как геолокация или известная репутация IP-адресов.

Фаза аналитики & ML :

- Используйте статистический анализ для идентификации базовых показателей активности в зависимости от времени суток или ролей пользователей.
- Применяйте модели машинного обучения (например, кластеризация, аномалий-детектирование) для обнаружения отклонений от нормы.

Фаза визуализации :

- Создайте дашборды (shiny, shinydashoard, flexdashboard, Quarto dashboard), демонстрирующие нормальные и аномальные паттерны сетевого трафика со временем.
- Подчеркните конкретные аномалии на картах потоков данных и в сводных докладах о предупреждениях.

Анализ Git репозиториев

Создание поведенческого профиля разработчика, анализ аномалий

Фаза ETL данных

- Извлеките информацию о комитах.
- Очистка и нормализация данных.
- Постройте хронологически последовательную историю изменений файлов репозитория.

Фаза аналитики & ML :

- Проанализируйте характер вносимых изменений (код, комментарии, конфигурация, документация…).
- Создайте профиль разработчика (предпочитаемый язык, статистические характеристики LoC на коммит, размер комментариев к коммиту, рабочие часы…)

Фаза визуализации :

- Покажите возможные аномалии в поведенческом паттерне разработчиков
- Покажите профиль разработчиков (тепловые карты, радар-карты…), оцените проект(репозиторий) в целом.

Ключевые навыки

R, работа с API/данными, Docker, Shiny/Quarto, суммаризация с использованием LLM, составление онтологий предметной области информационной безопасности

Погружение в проблематику:

1. Data Driven Security
2. Работа с LLM из R
3. Реализация RAG в R

Экспресс-анализ бинарных файлов с использованием Radare2

Классификация бинарных файлов вредоносного программного обеспечения для экспресс анализа в ходе расследования инцидентов информационной безопасности

Фаза ETL данных

- Создайте набор тестовых бинарных файлов с различными типами содержимого (полезные программы, потенциально зловредные исходники - например, VirusTotal, MalwareBazaar)
- Составьте базу данных известных зловредных доменов и IP-адресов, используя различные источники обмена информацией о киберугрозах
- Используйте Radare2 для разбора и анализа выбранных бинарных файлов
- Очистка и нормализация данных.

Фаза аналитики & ML :

- Автоматизируйте поиск строк доменных имен или IP адресов в бинарном коде
- Используйте статические анализаторы для выявления популярных видов уязвимостей

Фаза визуализации :

- Разработайте дашборды, которые отображают найденные IoC, уязвимости и оценку их опасности.

Тематический отбор новостных материалов из новостных агрегаторов (TT-RSS)

Разработка R-пакета для сбора и тематической категоризации новостей через API TT-RSS

Идея

Формирование тематического корпуса текстов из системы сбора и анализа новостных лент TT-RSS через API с последующей автоматизированной категоризацией и структурированием.

Описание

Проект включает следующие этапы:

1. Развертывание макета системы TT-RSS (docker/docker-compose).
2. Поиск и добавление источников данных в TT-RSS
3. Разработка средства сбора данных через API системы TT-RSS и представления их в виде единого датафрейма (/data-raw).
4. Создание средства тематического группирования новостной информации и формирования корпуса текстов с возможностью сохранения в файл/СУБД.
5. Разработка средства визуализации собранных данных в виде веб-приложения или сайта (Shiny/Quarto).
6. Создание средства упаковки в контейнер (`Dockerfile`).
7. Разработка средства запуска веб-приложения (`docker compose/podman`).
8. Разработка MCP сервера для TT-RSS.

Ключевые навыки

R, работа с API, Docker, Shiny/Quarto, текстовый анализ, MCP серверы

Погружение в проблематику:

1. Tiny Tiny RSS Documentation - официальная документация TT-RSS
2. GitHub | tt-rss/tt-rss: Free, Flexible, Open-Source News Feed - исходный код и документация TT-RSS проекта

Обогащение материалов киберразведки из материалов расследований

Разработка системы сбора информации научных публикаций для обогащения материалов киберразведки

Идея

Создание системы сбора информации о научных публикаций (https://arxiv.org/) для сбора материалов по теме информационной безопасности, threat intelligence и новым TTP наступательной кибербезопасности.

Описание

1. По заранее выбранным рубрикам осуществить сбор информации (метаинформации) о публикации новых научных статей по интересующей тематике.
2. Сохранение метаинформации статей в единый датафрейм
3. Организация хранения извлеченной информации, организация поиска по ней, построение дашбордов и анализ
4. Создание средства тематического группирования информации (метаинформации) о публикациях и формирования корпуса текстов с возможностью сохранения в файл/СУБД.
5. Разработка средства визуализации собранных данных в виде веб-приложения или сайта (Shiny/Quarto).
6. Создание средства упаковки в контейнер (`Dockerfile`).
7. Разработка средства запуска веб-приложения (`docker compose/podman`).

Ключевые навыки

R, работа с API, Docker, Data Engineering

Погружение в проблематику:

1. На переднем крае науки: анализ статей arxiv.org / Хабр / Копия в кеше
2. Arxiv – Cosmos 1.0: a multidimensional map of the emerging technology frontier

Сайт курса

https://i2z1.ddslab.ru/MLCTH

Дополнительные источники

1. https://r-pkgs.org/
2. Книга Алексея Селезнева про разработку пакетов на R
3. Разработка на Rust для пакетов на R
4. Интеграция за 15 минут кода на C в пакет R